

보안등급
대외비

	정보보호 담당자	정보보호 관리자	정보보호 책임자
결재			

개인정보보호 내부관리계획

2025.6

대성전산(주)

제/개정 이력표

개정번호	일자	제/개정 내용	작성자	승인자
1.0	2013-05-03	제정 및 승인	성현경	대표이사
2.0	2015-03-23	재승인	성현경	대표이사
3.0	2016-10-31	제 23 조	하기수	대표이사
4.0	2017-09-20	제 8 조, 제 18 조, 제 20 조, 제 26 조, 제 32 조	하기수	대표이사
5.0	2018-07-16	제 3 조(정의), 제 6 조(개인정보보호책임자의 지정 및 임무), 제 15 조(폐쇄회로 텔레비전의 설치 및 관리), 제 21 조(비밀번호 관리), 제 31 조(개인정보침해사실의 신고), 제 32 조(개인정보 유출 통지 등)	하기수	개인정보 보호책임자
6.0	2019-07-18	리뉴얼	하기수	대표이사
6.1	2019.12.30	변경 : 제 3 조, 제 7 조, 제 16 조 추가 : 제 13 조, 제 21 조, 제 22 조	하기수	개인정보 보호책임자
6.2	2021-05-17	p.6) '개인정보 보호책임자의 지정' 변경 p.12) '침해사고 유출등의 통지·신고' 변경	성현경	개인정보 보호책임자
6.3	2022-04-05	바이오 정보 -> 생체정보 용어 변경 및 생체인식정보 정의 추가 제 7 조 개인정보 보호책임자의 의무와 책임 조항 강화	성현경	개인정보 보호책임자
6.4	2023-05-19	제 13 조 4 항, 6 항 현행화 제 15 조 7 항 내용 수정 제 19 조 업데이트 주기 현행화 제 20 조 보유기간 현행화	성현경	개인정보 보호책임자
6.5	2024-06-19	제 3 조(용어의 정의) 영상정보처리기기 -> 고정형영상정보처리기기, 이동형 영상정보처리기기 로 용어재정의 제25조((개인정보 유출등의 통지 · 신고) ①항 : 통지, 신고시간을 24 시간에서 72 시간으로 변경함	성현경	개인정보 보호책임자
6.6	2025-06-05	개인정보보호법 개정 사항 반영 및 마스킹 기준 추가	성현경	개인정보 보호책임자

목차

제1장 총칙.....	5
제1조 (목적).....	5
제2조 (적용 범위).....	5
제3조 (용어 정의).....	5
제2장 내부관리계획의 수립 및 시행	6
제4조 (내부관리계획의 수립 및 승인)	6
제5조 (내부관리계획의 공표).....	7
제3장 개인정보 보호책임자의 의무와 책임	7
제6조 (개인정보 보호책임자의 지정).....	7
제7조 (개인정보 보호책임자의 의무와 책임).....	7
제8조 (비상보고체계의 수립).....	7
제9조 (개인정보취급자의 범위 및 의무와 책임).....	8
제10조 (개인정보취급자의 제한)	8
제4장 개인정보의 기술적·관리적 보호조치	8
제11조 (물리적 접근제한)	8
제12조 (출력 복사 시 보호조치 및 데이터 삭제와 저장매체 파기).....	8
제13조 (개인정보취급자 접근권한 관리 및 인증).....	9
제14조 (개인정보의 암호화 및 마스킹)	9
제15조 (접근통제)	10
제16조 (접속기록의 보관 및 점검).....	11
제17조 (위험도 분석 및 대응방안 마련).....	11
제18조 (개인정보 파기).....	12
제19조 (보안프로그램의 설치 및 운영)	12
제20조 (영상정보처리기기 설치/운영 및 관리).....	12
제21조 (개인정보 재위탁 금지).....	12
제22조 (위탁받은 개인정보 목적 외 이용 금지).....	12
제5장 개인정보보호 교육	13
제23조 (개인정보보호 교육 계획의 수립).....	13
제24조 (개인정보보호 교육의 실시).....	13
제6장 개인정보 침해대응	13
제25조 (개인정보 유출등의 통지 · 신고).....	13
제26조 (개인정보 유출등의 조치).....	14
제27조 (재해·재난 대비 안전조치).....	14
제28조 (손해배상보험·공제 가입 또는 준비금 적립).....	14

부칙.....	1 4
제1조 (시행일).....	1 4
제2조 (예외적용).....	1 4
제3조 (경과조치).....	1 5
관련 서식.....	1 5
[별표 1] 개인정보보호 손해배상책임보험 등 최저가입금액 기준.....	1 5

제1장 총칙

제1조 (목적)

개인정보 내부관리계획(이하 '내부관리계획'이라 한다)은 개인정보 보호법의 내부관리계획 수립 및 시행 의무에 따라 제정된 것으로 대성전산(주) (이하 '회사'라 한다)가 처리하는 개인정보를 체계적으로 관리하여 개인정보가 분실, 도난, 유출, 변조, 훼손, 오·남용 등이 되지 아니하도록 함을 목적으로 한다.

제2조 (적용 범위)

이 계획은 정보통신망을 통하여 수집, 이용, 제공 또는 관리되는 개인정보뿐만 아니라 서면 등 정보통신망 이외의 수단을 통해서 수집, 이용, 제공 또는 관리되는 개인정보에 대해서도 적용되며, 신용정보의 이용 및 보호에 관한 법률의 개인신용정보를 포함한 개인정보를 취급하는 내부 임직원 및 외부업체 직원에 대해 적용된다

제3조 (용어 정의)

이 계획에서 사용하는 용어의 정의는 다음과 같다.

1. "개인정보"란 살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보(해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다.
2. "개인신용정보"란 신용정보 중 개인의 신용도와 신용거래능력 등을 판단할 때 필요한 정보이며, 기업 및 법인에 관한 정보를 제외한 살아 있는 개인에 관한 정보로서 성명·주민등록번호 등을 통하여 개인을 알아볼 수 있는 정보를 말한다.(해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 정보를 포함)
3. "처리"란 개인정보의 수집, 생성, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정(訂正), 복구, 이용, 제공, 공개, 파기(破棄), 그 밖에 이와 유사한 행위를 말한다.
4. "정보주체"란 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람을 말한다.
5. "개인정보처리자"란 업무를 목적으로 개인정보파일을 운영하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등을 말한다.
6. "개인정보 보호책임자"란 회사의 개인정보보호 업무 및 조직을 총괄하여 지휘하는 자를 말한다.
7. "개인정보 보호관리자"란 개인정보 보호책임자를 보좌하여 개인정보보호 업무에 대한 실무를 총괄하고 관리하는 자를 말한다.
8. "개인정보 보호담당자"란 개인정보 보호관리자를 보좌하여 개인정보보호 업무에 대한 실무를 담당하고 지원하는 자를 말한다.
9. "개인정보취급자"란 사업장 내에서 정보주체의 개인정보를 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 하는 자를 말한다.
10. "개인정보처리시스템"이라 함은 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말한다. 일반적으로 데이터베이스(DB) 내의 데이터에 접근할 수 있도록 해주는 응용시스템을 의미하며, 데이터베이스를 구축하거나 운영하는데 필요한 시스템을 말한다.
11. "망분리"라 함은 외부 인터넷망을 통한 불법적인 접근과 내부정보 유출을 차단하기 위해 업무망과 외부 인터넷망을 분리하는 망 차단조치를 말한다.
12. "접속기록"이란 개인정보처리시스템에 접속하는 자가 개인정보처리시스템에 접속하여 수행한 업

- 무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 전자적으로 기록한 것을 말한다. 이 경우 "접속"이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태를 말한다.
13. "생체정보"란 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 개인을 식별할 수 있는 신체적, 생리적, 행동적 특징에 관한 정보로서 특정 개인을 인증·식별하거나 개인에 관한 특징을 알아보기 위해 일정한 기술적 수단을 통해 처리되는 정보를 포함한다.
14. "생체인식정보"란 생체정보 중 특정 개인을 인증 또는 식별할 목적으로 일정한 기술적 수단을 통해 처리되는 정보를 말한다.
15. "위험도 분석"이란 개인정보 유출에 영향을 미칠 수 있는 다양한 위험요소를 식별·평가하고 해당 위험요소를 적절하게 통제할 수 있는 방안 마련을 위한 종합적으로 분석하는 행위를 말한다.
16. "보조저장매체"란 이동형 하드디스크(HDD), 유에스비(USB)메모리 등 자료를 저장할 수 있는 매체로서 개인정보처리시스템 또는 개인용 컴퓨터 등과 쉽게 연결·분리할 수 있는 저장매체를 말한다.
17. "모바일 기기"란 무선망을 이용할 수 있는 스마트폰, 태블릿 컴퓨터 등 개인정보 처리에 이용되는 휴대용 기기를 말한다.
18. "고정형 영상정보처리기기"란 일정한 공간에 설치되어 지속적 또는 주기적으로 사람 또는 사물의 영상 등을 촬영하거나 이를 유·무선망을 통하여 전송하는 장치로서 대통령령으로 정하는 장치를 말한다.
19. "이동형 영상정보처리기기"란 사람이 신체에 착용 또는 휴대하거나 이동 가능한 물체에 부착 또는 거치(據置)하여 사람 또는 사물의 영상 등을 촬영하거나 이를 유·무선망을 통하여 전송하는 장치로서 대통령령으로 정하는 장치를 말한다.
20. "인증정보"란 개인정보처리시스템 또는 정보통신망을 관리하는 시스템 등에 접속을 요청하는 자의 신원을 검증하는데 사용되는 정보를 말한다.
21. "내부망"이란 물리적 망분리, 접근 통제시스템 등에 의해 인터넷 구간에서의 접근이 통제 또는 차단되는 구간을 말한다.
- ※ 개인정보보호법의 "개인정보"와 신용정보의 이용 및 보호에 관한 법률의 "개인신용정보"를 통칭하여 이하 "개인정보"라고 명칭한다.

제2장 내부관리계획의 수립 및 시행

제4조 (내부관리계획의 수립 및 승인)

- ① 개인정보 보호관리자는 회사의 개인정보보호를 위한 전반적인 사항을 포함하여 내부관리계획을 수립하여야 한다.
- ② 내부관리계획 수립 시 개인정보보호와 관련한 법령 및 관련 규정을 준수하도록 하여야 한다.
- ③ 개인정보 보호책임자는 개인정보 보호관리자가 수립한 내부관리계획의 타당성을 검토하여 개인정보 보호를 위한 내부관리계획을 승인하여야 한다.
- ④ 개인정보 보호관리자는 개인정보보호 관련 법령의 제·개정 사항 등을 반영하기 위하여 매년 내부관리계획의 타당성과 개정 필요성을 검토하고 개인정보 보호책임자가 승인할 수 있다.
- ⑤ 개인정보 보호관리자는 내부관리계획의 중요한 변경이 있는 경우 이를 즉시 반영하여 내부관리계획을 수정하며 개인정보 보호책임자의 승인 후 시행한다.

- ⑥ 개인정보 보호관리자는 내부관리계획의 수정 시 수정 이력을 관리해야 한다.

제5조 (내부관리계획의 공표)

- ① 개인정보 보호책임자는 제4조에 따라 승인한 내부관리계획을 매년 전 임직원에게 공표한다.
- ② 내부관리계획은 임직원이 언제든지 열람할 수 있는 방법으로 비치하여야 하며, 변경사항이 있는 경우에는 이를 공지하여야 한다.

제3장 개인정보 보호책임자의 의무와 책임

제6조 (개인정보 보호책임자의 지정)

회사는 다음 각 호의 어느 하나에 해당하는 지위에 있는 자 중에서 개인정보 보호책임자로 임명한다.

1. 사업주 또는 대표자
2. 임원(임원이 없는 경우에는 개인정보 처리 관련 업무를 담당하는 부서의 장)

제7조 (개인정보 보호책임자의 의무와 책임)

- ① 개인정보 보호책임자는 정보주체의 개인정보보호를 위하여 다음 각 호의 임무를 수행한다.
1. 개인정보 보호관리자(담당자) 및 개인정보취급자의 의무와 책임 규정 및 총괄 관리
 2. 개인정보 보호 계획의 승인
 3. 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선 총괄
 - 임직원 또는 제3자에 의한 위법·부당한 개인정보 침해행위에 대한 점검·대응·사후조치 총괄
 4. 개인정보 처리와 관련한 불만의 처리 및 피해 구제 총괄
 5. 개인정보 보호 교육 계획의 수립 및 시행 총괄
 6. 개인정보 유출 및 오용·남용 방지를 위한 내부통제시스템의 구축 이행 총괄
 7. 개인정보파일의 보호 및 관리·감독 총괄
 8. 개인정보 처리방침의 수립·변경 및 시행 총괄
 9. 개인정보 보호 관련 자료의 관리·감독 총괄
 10. 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기 총괄
 11. 연 1회 이상으로 내부관리계획의 이행 실태 점검·관리
 12. 기타 정보주체의 개인정보보호에 필요한 사항
- ② 개인정보취급자를 최소한으로 제한하여 지정하고 수시로 관리·감독하여야 한다.
- ③ 개인정보취급자에 대한 교육 및 보안서약 등을 통해 개인정보 침해사고를 사전에 예방한다.
- ④ 개인정보 관련 업무의 효율적 운영을 위하여 정보보호 또는 개인정보 관리 전담부서의 직원을 개인정보 보호관리자와 개인정보 보호담당자로 임명할 수 있다.
- ⑤ 개인정보 보호관리자는 개인정보 보호책임자를 보좌하여 개인정보보호 업무에 대한 실무를 총괄하고 관리한다.
- ⑥ 개인정보 보호담당자는 개인정보 보호관리자를 보좌하여 개인정보보호 업무에 대한 실무를 담당하고 지원한다.

제8조 (비상보고체계의 수립)

개인정보 보호책임자는 개인정보 유출 등 사고 발생 시 현업부서로부터 임원진까지 보고될 수 있도록

비상보고 체계를 수립한다.

1. 사고발생
2. 현업부서에서 사고감지
3. 개인정보 보호책임자에게 사고경위 및 피해현황 보고
4. 개인정보 보호책임자가 대표이사에게 보고

제9조 (개인정보취급자의 범위 및 의무와 책임)

- ① 개인정보취급자의 범위는 회사 내에서 정보주체들의 개인정보 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 수행하는 자를 말하고, 정규직 이외에 임시직, 계약직 직원도 포함될 수 있다. 또한 개인정보취급자 현황을 문서로 관리하여야 한다.
- ② 개인정보취급자는 정보주체의 개인정보보호와 관련하여 다음과 같은 역할 및 책임을 이행한다.
 1. 개인정보보호 활동 참여
 2. 내부관리계획의 준수 및 이행
 3. 개인정보의 안전성 확보조치 기준 이행
 4. 임직원 또는 제3자에 의한 위법·부당한 개인정보 침해행위에 대한 점검 등
 5. 업무상 알게 된 개인정보를 제3자에게 제공하지 않음
 6. 기타 정보주체의 개인정보보호를 위해 필요한 사항의 이행

제10조 (개인정보취급자의 제한)

회사는 개인정보를 취급할 수 있는 자를 다음 각 호의 하나 이상에 해당하는 자로 정하여 최소한으로 제한하여야 한다.

1. 정보주체를 직접 상대로 하여 업무를 수행하는 자
2. 데이터베이스를 포함한 전산 관련 업무를 수행하는 자
3. 기타 업무상 개인정보의 취급이 불가피한 자

제4장 개인정보의 안전성 확보조치

제11조 (물리적 접근제한)

- ① 회사는 개인정보와 개인정보처리시스템에 대해 물리적 잠금장치 등 보호조치를 취하여야 한다.
- ② 회사는 전산실, 자료보관실 등 개인정보를 보관하고 있는 물리적 보관 장소를 별도로 두고 있는 경우에는 이에 대한 출입통제 절차를 수립·운영하여야 한다.
- ③ 물리적 접근방지를 위한 별도의 보호시설에 출입하거나 개인정보를 열람하는 경우, 그 출입자에 대한 출입사실 및 열람 내용에 관한 관리대장을 작성하도록 하여야 한다.
- ④ 출입관리대장의 출입 및 열람 내용을 주기적으로 점검하여야 한다.
- ⑤ 보호구역 설정기준에 따라 경고표시(경고판)를 부착하여야 한다.
- ⑥ 방문자(외부인) 출입에 대한 관리대장을 작성하도록 하여야 하고 주기적으로 점검하여야 한다.
- ⑦ 회사 내의 모든 시스템, 서버, PC에 대하여 반·출입 이력 관리대장을 작성하도록 하여야 하고, 반·출입 담당자를 지정하고 주기적으로 점검하여야 한다.

제12조 (출력 복사 시 보호조치 및 데이터 삭제와 저장매체 파기)

- ① 회사는 개인정보처리시스템에서 개인정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여

야 하며, 용도에 따라 출력 항목을 최소화 하여야 한다.

- ② 회사는 개인정보 업무처리를 목적으로 개인정보의 조회, 출력 등의 업무를 수행하는 과정에서 개인정보보호를 위하여 개인정보를 마스킹하여 표시제한 조치를 취할 수 있다.
- ③ 개인정보가 포함된 정보를 출력하거나 복사할 경우에 개인정보 유출사고를 방지하기 위한 보호조치(안전한 장소에 보관)를 취하여야 한다.
- ④ 개인정보의 이용을 위하여 출력 및 복사한 개인정보의 이용 목적이 완료된 경우 분쇄기로 분쇄하거나 소각하는 등의 안전한 방법으로 파기하고, 필요 시 개인정보 폐기확인서를 작성한다.
- ⑤ 개인정보처리시스템 및 개인정보 취급 PC의 파기 시 저장매체 내 데이터가 복구될 수 없도록 물리적 파기 및 관련 증적을 기록하여야 한다.
- ⑥ 회사는 사용기간이 만료된 개인정보를 복구되지 아니하도록 완전 삭제에 대한 지침을 수립하고 실시하여야 한다.

제13조 (개인정보취급자 접근권한 관리 및 인증)

- ① 개인정보처리시스템에 대한 접근 권한(개인정보 조회, 화면 출력 등)을 서비스 제공에 필요한 최소한의 인원에게만 부여하여야 하고 권한이 부여된 인원의 적정성을 점검하여야 한다.
- ② 개인정보취급 업무를 담당하는 임직원의 담당업무에 따라 개인정보 취급권한(1인 1계정)을 부여하며, 부서별/직급별에 따라 개인정보에 대한 접근권한(읽기/쓰기/수정 및 삭제 권한)을 차등 부여한다. 단, 업무목적으로 공용ID를 사용하는 경우 책임자 승인 후 사용이력을 작성한다.
- ③ 권한회수 절차에 따라 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근권한을 변경 또는 말소한다.
- ④ 회사는 개인정보취급자가 생일, 주민등록번호, 전화번호 등 추측하기 쉬운 숫자나 개인관련 정보를 패스워드로 이용하지 않도록 비밀번호 작성규칙 및 비밀번호 변경주기를 설정하고, 이를 적용 운용하여야 한다. 또한, 비밀번호 작성규칙 및 변경 주기는 아래와 같다.
 1. 영문, 숫자, 특수문자 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성
 2. 분기별 1회 이상 변경
- ⑤ 회사는 제2항과 제3항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관한다.
- ⑥ 보안서약서 관리 기준에 따라 개인정보를 취급하는 모든 임직원에게 대하여 입·퇴사시 보안서약서를 작성하도록 하여야 한다.(1년마다 보안서약서를 갱신하여 작성하도록 하여야 한다)
- ⑦ 회사는 정당한 권한을 가진 개인정보취급자만 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 기술적 조치를 하여야 한다.

제14조 (개인정보의 암호화 및 마스킹)

- ① 회사는 이용자 및 이용자가 아닌 정보주체 대하여 아래와 같은 정보를 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.
 1. 이용자 : 인증정보(비밀번호, 생체인식정보 등), 고유식별정보(주민등록번호, 여권번호, 운전면허번호, 외국인등록번호), 신용카드번호 및 계좌번호
 2. 이용자가 아닌 정보주체 : 인증정보(비밀번호, 생체인식정보 등), 주민등록번호, 주민등록번호 외 고유식별정보(DMZ에 저장하는 경우)

3. 비밀번호 및 개인식별정보는 복호화 되지 아니하도록 일방향 암호화하여 저장하여야 한다.
- ② 정보통신망을 통하여 아래와 같은 정보를 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다.
 1. 모든 정보통신망 : 인증정보(비밀번호 및 생체인식정보 등)
 2. 인터넷망 구간 : 개인정보
- ③ 회사는 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 상용 암호화 소프트웨어 또는 안전한 암호화 알고리즘을 사용하여 암호화한 후 저장하여야 한다.
- ④ 회사는 개인정보처리시스템의 개인정보를 마스킹 기준을 수립하고 설정하여야 한다.
- ⑤ 회사는 암호화된 개인정보를 안전하게 보관하기 위하여 안전한 암호 키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행하여야 한다.

제15조 (접근통제)

- ① 회사는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음 각 호의 기능을 포함한 조치를 하여야 한다.
 1. 개인정보처리시스템의 접속 권한을 IP 주소 등으로 제한하여 인가 받지 않은 접근 제한
 2. 개인정보처리시스템에 접속한 IP 주소 등을 재분석하여 불법적인 개인정보 유출 시도 탐지 및 대응
- ② 회사는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다.
- ③ 회사는 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상일 경우 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 대한 인터넷망 차단 조치를 하여야 한다. 다만, 클라우드컴퓨팅서비스를 이용하여 개인정보처리시스템을 구성·운영하는 경우에는 해당 서비스에 대한 접속 외에는 인터넷을 차단하는 조치를 하여야 한다.
- ④ 회사는 취급중인 개인정보가 인터넷 홈페이지, P2P, 공유설정(공유폴더) 등을 통해 열람권한이 없는 자에게 공개되지 않도록 개인정보처리시스템 및 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 취하여야 한다.
 1. 도박, 증권, 음란, 토렌트, 웹하드, P2P, 클라우드 서비스 또는 사이트에 대한 접속을 제한
 2. 협력업체 내에서 허용된 소프트웨어 이외의 크랙, 불법 프로그램의 설치 또는 사용을 제한
- ⑤ 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 시스템 접속이 차단되도록 하여야 한다.
- ⑥ 회사 내 업무를 목적으로 무선 AP(공유기) 사용 시 안전하게 보호하도록 조치하여야 한다.
- ⑦ 회사는 외부저장매체를 보안솔루션을 사용하여 통제하거나 솔루션 통제가 불가능 할 경우 보안실 등 다른 물리적 통제조치를 적용할 수 있다.
- ⑧ 시스템에 대한 접근시도를 확인하기 위해 운영체제의 감사 정책을 설정하도록 조치를 취하여야 한다.
- ⑨ 고유식별정보를 처리하는 경우 인터넷 홈페이지를 통해 고유식별정보가 유출·변조·훼손되지 않도록

연 1회 이상 취약점을 점검하고 필요한 보완 조치를 하여야 한다.

제16조 (접속기록의 보관 및 점검)

- ① 회사는 개인정보취급자가 개인정보처리시스템에 접속한 사실을 확인하는데 필요한 정보(접속기록)를 전자적으로 기록하여야 한다.
 - 식별자: 개인정보처리시스템에서 접속자를 식별할 수 있도록 부여된 ID 등 계정 정보
 - 접속일시: 접속한 시점 또는 업무를 수행한 시점(년-월-일, 시:분:초)
 - 접속지 정보: 접속자의 PC, 모바일기기 등 단말기 정보 또는 서버의 IP주소 등 접속 주소
 - 처리한 정보주체 정보 : 개인정보취급자가 누구의 개인정보를 처리하였는지를 알 수 있는 식별정보(ID, 고객번호, 학번, 사번 등)
 - 수행업무: 개인정보처리시스템을 이용한 개인정보 처리 내용을 알 수 있는 정보
- ※ 개인정보에 대한 수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정(訂正), 복구, 이용, 제공, 공개, 파기(破棄) 등이 수행업무에 해당될 수 있다.
- ② 회사는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 월 1회 이상 정기적으로 확인·감독하여야 한다.
- ③ 회사는 개인정보처리시스템에 접속한 개인정보취급자의 접속기록을 1년 이상 보관·관리하여야 한다. 다만, 5만명 이상 개인정보를 처리하거나 고유식별정보 또는 민감정보를 처리하는 시스템은 최소 2년 이상 접속기록을 보존·관리하여야 한다.
- ④ 개인정보처리시스템의 접속기록이 위·변조되지 않도록 안전하게 보관하여야 하며 정기적인 백업을 수행하여야 한다.
- ⑤ 정기적으로 접속기록을 확인하여 개인정보취급자 등이 개인정보처리시스템에 접속하여 개인정보를 다운로드한 경우 그 사유를 반드시 확인해야 한다.
 1. 업무시간 외 개인정보처리시스템에 접근하여 개인정보를 다운로드한 경우
 2. 평시와 비교하여 개인정보 다운로드 대상이 비정상적으로 많을 경우
 3. 특정 사용자의 개인정보 다운로드 횟수가 급격히 늘어난 경우
 4. 기타 개인정보 유출이 의심스러운 경우 등

제17조 (위험도 분석 및 대응방안 마련)

- ① 회사의 정보보호 요구사항을 파악하고, 정보 혹은 다른 자산의 기밀성, 무결성, 가용성을 유지할 수 없게 하는 잠재적인 요소 및 현재 구현된 통제와 취약성 및 위협에 대한 대응이 실패할 수 있는 실제적인 가능성을 파악하여 보다 비용대비 효과적인 보안 대책을 마련하기 위하여 위험평가를 실시 한다.
- ② 자산분석, 위협 분석, 취약성 분석의 각 단계를 수행하여 위험을 평가한다.
 1. 자산 분석
 2. 위협 분석
 3. 취약성 분석
 4. 위험도 산정
 5. 보호대책 선정
 6. 정보보호계획 수립
- ③ 위험평가는 연 1회 이상 실시하며, 취약점 점검이 완료된 후 실시 한다.

제18조 (개인정보 파기)

- ① 개인정보의 수집·이용 목적의 달성 또는 보유 기한이 만료된 경우 개인정보는 지체 없이 파기되어야 한다.
- ② 개인정보 문서 및 데이터, 이동매체를 파기하는 경우 파쇄기, 소각, 용해 등 재생할 수 없는 기술적 방법을 사용하여 삭제하여야 하며, 개인정보 보호관리자는 파기 여부를 확인하여야 한다.

제19조 (보안프로그램의 설치 및 운영)

- ① 회사는 개인용 컴퓨터(PC) 등을 이용하여 개인정보를 취급하는 경우 개인정보가 분실, 도난, 유출, 변조 또는 훼손되지 아니하도록 보안패치, 공유폴더 제한 등 보호조치와 백신 프로그램 등 보안 프로그램을 설치·운영하여야 한다.
- ② 보안 프로그램은 정당한 사유가 없는 한 항상 최신의 버전으로 업데이트를 적용하여야 하고 실시간 감시 및 예약검사 기능을 적용하여야 한다.
- ③ PC는 항상 최신 보안 패치가 설치되어야 하며 자동업데이트로 설정하여야 한다.
(단 내부망의 PC는 주1회 이상 업데이트를 진행한다.)
- ④ 악성프로그램 관련 경보가 발령된 경우 또는 사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우, 정당한 사유가 없는 한 즉시 이에 따른 업데이트를 실시하여야 한다.

제20조 (고정형 영상정보처리기기 설치/운영 및 관리)

- ① 공개된 장소일지라도 개인의 사생활 침해 우려가 있는 경우에는 설치할 수 없다.
- ② 녹음기능의 사용 및 설치 목적과 다른 고정형 영상정보처리기기의 임의조작은 금지한다.
- ③ 고정형 영상정보처리기기 안내판은 촬영범위 내에서 정보주체가 인지하기 쉬운 곳에 부착하며 다음 사항을 포함해야 한다.
 1. 설치 목적 및 장소
 2. 촬영 범위 및 시간
 3. 관리책임자의 연락처
 4. (고정형 영상정보처리기기 설치/운영을 위탁한 경우) 수탁자 및 연락처
- ④ 고정형 영상정보처리기기 운영자는 영상정보처리기기 운영·관리 방침을 마련하여야 한다.
- ⑤ 고정형 영상정보처리기기 관리 책임자를 지정하여 수집된 영상정보의 목적 외 이용 및 제3자 제공 금지 등 법적 준거성 확보를 위한 관리를 해야 한다.
- ⑥ 수집된 고정형 영상정보는 보유기간(3개월 이내) 만료 시 즉각 삭제해야 한다.
- ⑦ 고정형 영상정보처리기기 운영자는 개인정보가 분실·도난·유출·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.
- ⑧ 이동형 영상정보처리기로 공개된 장소에서 업무를 목적으로 사람 또는 그 사람과 관련된 사물의 영상을 촬영할 수 없도록 원칙적으로 금지한다.

제21조 (개인정보 재위탁 금지)

- ① 개인정보보호법, 신용정보의 이용 및 보호에 관한 법률을 통해 위탁 받은 개인정보의 처리를 제3자에게 재위탁해서는 아니된다.

제22조 (위탁받은 개인정보 목적 외 이용 금지)

- ② 개인정보보호법, 신용정보의 이용 및 보호에 관한 법률을 통해 위탁 받은 개인정보는 위탁받은 업무를 초과하여 이용하거나 제공해서는 아니된다.

제5장 개인정보보호 교육

제23조 (개인정보보호 교육 계획의 수립)

- ① 개인정보 보호책임자는 다음 각 호의 사항을 포함하는 연간 개인정보보호 교육계획을 매년 수립하여 운영 할 수 있다.
 - 1. 교육목적 및 대상
 - 2. 교육내용
 - 3. 교육 일정 및 방법
- ② 개인정보보호 교육을 실시한 이후에 교육의 성과와 개선 필요성을 검토하여 차년도 교육계획 수립에 반영하여야 한다.

제24조 (개인정보보호 교육의 실시)

- ① 개인정보 보호책임자는 정보주체의 개인정보보호에 대한 직원들의 인식제고를 위해 노력해야 하며, 개인정보의 오·남용 또는 유출 등을 적극 예방하기 위해 개인정보보호 교육을 개인정보취급자에 대해서는 정기적으로 1년에 1회 이상 실시하여야 하고, 그 외의 임직원에 대해서는 필요한 범위에 대하여 선택적으로 실시할 수 있다.
- ② 개인정보처리 업무를 위탁하고 있는 수탁자들을 대상으로 1회 이상의 교육을 실시한다.
- ③ 교육 방법은 집체교육 뿐만 아니라, 인터넷 교육, 그룹웨어 교육 등 다양한 방법을 활용하여 실시하고, 필요한 경우 외부 전문기관이나 전문요원에 위탁하여 교육을 실시할 수 있다.
- ④ 개인정보보호에 대한 중요한 전파 사례가 있거나 개인정보보호 업무와 관련하여 변경된 사항이 있는 경우, 회사는 수시 교육을 실시할 수 있다.

제6장 개인정보 침해대응

제25조 (개인정보 유출등의 통지 · 신고)

- ① 회사는 개인정보의 분실·도난·유출 사실을 안 때에는 지체 없이 72시간 이내에 다음 각 호의 모든 사항을 해당 정보주체에게 알려야 한다. 다만, 유출등이 된 개인정보의 확산 및 추가 유출등을 방지하기 위하여 접속경로의 차단, 취약점 점검 · 보완, 유출등이 된 개인정보의 회수 · 삭제 등 긴급한 조치가 필요한 경우에는 그 조치를 한 후 지체 없이 정보주체에게 알릴 수 있다.
 - 1. 유출등이 된 개인정보 항목
 - 2. 유출등이 발생한 시점과 그 경위
 - 3. 유출등으로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보
 - 4. 개인정보처리자의 대응 조치 및 피해 구제절차
 - 5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처
- ② 다만, 정보주체의 연락처를 알 수 없는 등 정당한 사유가 있는 경우에는 인터넷 홈페이지에 30일 이상 게시하는 것으로 통지를 갈음하는 조치를 취할 수 있다.
- ③ 회사는 아래 각 호와 같은 개인정보의 분실·도난·유출 사실을 안 때에는 지체 없이 72시간 이내에

개인정보보호위원회 또는 한국인터넷진흥원에 신고하여야 한다. 다만, 개인정보 유출등의 경로가 확인되어 해당 개인정보를 회수·삭제하는 등의 조치를 통해 정보주체의 권익 침해 가능성이 현저히 낮은 경우에는 신고하지 않을 수 있다.

1. 1천명 이상의 정보주체에 관한 개인정보가 유출등이 된 경우
2. 민감정보, 고유식별정보가 유출등이 된 경우
3. 외부로부터의 불법적인 접근에 의해 개인정보가 유출등이 된 경우

제26조 (개인정보 유출등의 조치)

- ① 회사는 유출 사고 발생 시 신속한 대응을 통해 피해 발생을 최소화하기 위해 '개인정보 유출 사고 대응 매뉴얼'을 마련하고, 피해를 최소화할 수 있는 조치를 강구하여야 한다
- ② 개인정보 보호책임자는 개인정보가 침해되었다고 판단할만한 상당한 근거가 있고, 이를 방지할 경우 회복하기 어려운 침해가 발생할 우려가 있다고 인정되면 개인정보 보호관리자 또는 개인정보취급자에 대하여 다음 각 호에 해당하는 조치를 명할 수 있다.
 1. 개인정보 침해행위의 중지
 2. 개인정보 처리의 일시적인 정지
 3. 그 밖에 개인정보의 보호 및 침해방지를 위하여 필요한 조치

제27조 (재해·재난 대비 안전조치)

- ① 회사는 화재, 홍수, 단전 등의 재해·재난 발생 시 개인정보처리시스템 보호를 위한 IT재해복구 대응 매뉴얼 등 대응절차를 마련하고 정기적으로 점검하여야 한다.
- ② 재해·재난 발생 시 개인정보처리시스템 백업 및 복구를 위한 계획을 마련하여야 한다

제28조 (손해배상보험·공제 가입 또는 준비금 적립)

- ① 회사는 개인정보보호 법령 위반으로 이용자에게 손해를 입힌 경우 손해배상책임 이행을 위하여 개인정보보호 손해배상보험 또는 공제에 가입하거나 준비금을 적립하는 등의 필요한 조치를 하여야 한다.
- ② 손해배상보험 또는 공제에 가입하는 경우 최저가입금액은 '[별표 1] 개인정보보호 손해배상책임보험 등 최저가입금액 기준'을 참고하고, 보험의 최저가입금액은 회사가 저장·관리하는 '이용자수' 및 '매출액' 규모에 따라 차등 설정하여 최소 0.5억원~최대 10억원으로 정할 수 있다.

부칙

제1조 (시행일)

이 지침은 대표이사(또는 위임을 받은 개인정보 보호책임자)의 승인일로부터 시행한다.

제2조 (예외적용)

다음 각 호에 해당하는 경우에는 이 계획에서 명시한 내용일지라도 정보보호 최고책임자의 승인을 받아 예외적으로 취급할 수 있다.

1. 기술환경의 변화로 적용할 수 없는 경우
2. 기술적, 관리적 필요에 따라 지침의 적용을 보류할 긴급한 사유가 있는 경우
3. 기타 재해 등 불가항력적인 상황일 경우

제3조 (경과조치)

특별한 사유에 의하여 이 계획에서 정하는 요건을 충족하지 못한 경우에는 시행일로부터 1년 이내에 개선방안을 마련하여야 한다.

관련 서식**[별표 1] 개인정보보호 손해배상책임보험 등 최저가입금액 기준**

보험 등 가입금액 산정조건		③ 최저 가입금액
① 이용자수	② 매출액	
100만명 이상	800억원 초과	10억원
	50억원 초과 800억원 이하	5억원
	50억원 이하	2억원
10만명 이상 100만명 미만	800억원 초과	5억원
	50억원 초과 800억원 이하	2억원
	50억원 이하	1억원
1천명 이상 10만명 미만	800억원 초과	2억원
	50억원 초과 800억원 이하	1억원
	50억원 이하	0.5억원

[별표 2] 마스킹 기준

구분	변환 기준	변환 예시
주민등록번호, 외국인등록번호	생년 및 성별을 제외하고 마스킹 처리하되, 업무상 월일이 필요할 경우에 한해 월일 유지	900101-1234567 → 90****-1***** → (업무상 필요시) 900101-1*****
여권번호	첫 자리는 그대로 두고 뒷 2~9 자리를 마스킹	M12341234 → M*****
운전면허번호	첫 두자리 또는 면허 취득 지역 명을 제외하고 마스킹	서울-**-*****-** 11-**-*****-**
계좌번호 카드번호	첫 두자리를 제외하고 마스킹	20****-**-***** 40**-****-****-****
이름	- 첫 자리와 마지막 자리를 제외하고 마스킹 - 외자 이름일 경우 마지막 자리 마스킹	김구 > 김* 홍길동 > 홍*동 박혁거세 > 박**세
전화번호	- 지역번호, 통신사 번호는 마스킹하지 않음 - 그 외 국번 이하 번호 마스킹	02-123-1234 → 02-***-****
주소	업무상 필요 최소한의 정보만 표시 후 마스킹	서울시 관악구 *****